Auditoría y Cumplimiento

2 de octubre de 2026

Objetivo y puestos

Comprobar que la implementación cumple los requisitos, conservar resultados y preparar el informe con las aportaciones de cada área.

Auditoría tiene tres puestos: revisión de acceso físico y monitoreo, revisión de identidades y permisos, y documentación de resultados. Los responsables se asignan fuera del repositorio.

Laptop 1: pruebas. Laptop 2: informe y evidencias. Auditoría tiene consulta digital; no modifica el sistema para conseguir un resultado aprobado.

Paso 1. Preparar lista de cotejo

1. Leer las guías del laboratorio y las decisiones de implementación.
2. Copiar Plantillas/pruebas.csv y Plantillas/requisitos.csv.
3. Para cada requisito, identificar departamento responsable y evidencia esperada.
4. Registrar NVR virtual autorizado. Confirmar cómo se documentó el punto de transceptores de video.
5. Mantener estados pendiente, aprobado, falló y no disponible. Ninguno de los dos últimos significa cumplimiento.
6. Comprobar que cada prueba tenga condición inicial, pasos, esperado, obtenido y archivo de evidencia.

Paso 2. Revisar organización

1. Contar 31 personas distintas, no solo 31 IDs.
2. Verificar que todos los puestos tienen responsable en el control privado.
3. Verificar que resumen y filas de IAM coincidan con la decisión final.
4. Comparar tareas y entregables entre pestañas.
5. Verificar que todos tengan trabajo y que nadie quede sin tarea al combinar puestos.

Paso 3. Auditar RFID

1. Confirmar modelo y circuito contra su documentación.
2. Revisar código usado, no únicamente un archivo anterior.
3. Leer las cuatro tarjetas autorizadas y una no autorizada.
4. Observar UID, LED y CSV.
5. Seleccionar salida y repetir lectura; verificar dirección del evento.
6. Presentar rápidamente una tarjeta repetida y comprobar que no genera salida automática.
7. Revisar que los UID autorizados correspondan a cuatro identidades distintas.
8. Después de la baja, repetir tarjeta y comprobar rechazo.

Si no hay 31 tarjetas, separar revisión de lista de identidades y tarjetas realmente probadas. No reportar 27 lecturas rechazadas si solo probaron una tarjeta no autorizada.

Paso 4. Auditar NVR

1. Abrir ambas cámaras en el hub.
2. Abrirlas desde un teléfono de monitoreo.
3. Revisar configuración continua, retención y almacenamiento.
4. Reproducir un periodo sin movimiento; grabar solo movimiento no cumple el comportamiento continuo solicitado.
5. Exportar video con entrada y salida y abrirlo en otro equipo.
6. Revisar inicio/fin y cortes del periodo de prueba.
7. Confirmar que archivos y configuración sobreviven al reinicio de contenedor.
8. Declarar alcance de red del móvil y duración real de prueba.

Paso 5. Auditar Microsoft 365

Comprobar con TI: alta, modificación, restablecimiento de contraseña, licencia asignada, rol, desafío MFA, registros, análisis de amenazas disponible y eliminación de cuenta temporal.

Pedir evidencia de operaciones reales. Una vista de licencia vacía no demuestra asignación. Un teléfono registrado no demuestra que un inicio solicitó MFA. Una vista sin alertas se describe como tal; no inventar incidentes.

Confirmar que no se modificaron cuentas ajenas al laboratorio. Registrar funciones limitadas por licencia o permiso.

Paso 6. Auditar OneLogin y aplicación

1. Confirmar que login redirige al tenant real OneLogin.
2. Probar ingeniero, administrador, auditor y usuario sin acceso.
3. Verificar MFA en la política y en el login probado.
4. Mostrar mantenimiento permitido al ingeniero y denegado al auditor.
5. Probar alta desde OneLogin sin crear la cuenta manualmente en la aplicación.
6. Guardar evento de creación local y evento de aprovisionamiento OneLogin.
7. Cambiar rol y probar retiro de la función anterior.
8. Suspender usuario y esperar confirmación SCIM.
9. Probar nuevo acceso y una acción de sesión ya abierta. La baja no se considera efectiva en la aplicación hasta que llegó el cambio.
10. Revisar que la API sin token dé 401.

La aplicación es de práctica y sus acciones administrativas no modifican el sistema operativo. El resultado evaluado es que el servidor decide permisos correctamente y registra la acción.

Paso 7. Ejecutar recorrido integrado

1. RRHH muestra alta y autorización.
2. Visitante presenta tarjeta: acceso físico denegado.
3. Ingeniero presenta tarjeta: permitido.
4. Ingeniero inicia sesión con MFA OneLogin.
5. Ejecuta mantenimiento autorizado.
6. Auditor intenta mantenimiento y obtiene rechazo.
7. Ingeniero cierra sesión y registra salida.
8. Se realiza cambio de rol y baja al final.
9. SOC reconstruye la secuencia con horas, identidad, registros y video.

Registrar ID de prueba y archivo por cada paso. Si falla uno, conservar el fallo y repetir después de corregir, con nueva fecha.

Paso 8. Verificación de archivos

En una laptop Ubuntu, pueden crear una lista de huellas de los archivos finales, para comprobar después si cambiaron:

```
cd ~/lab-runtime/evidencias
find . -type f ! -name huellas.sha256 -print0 | sort -z | xargs -0 -r sha256sum > huellas.sha256
sha256sum -c huellas.sha256
```

La huella identifica contenido y cambios; no demuestra por sí sola que una prueba ocurrió. Mantener también fecha, responsable y descripción.

En Windows, para un archivo:

```
Get-FileHash .\video_entrada.mp4 -Algorithm SHA256
```

Paso 9. Preparar informe y presentación

1. Pedir a cada departamento su objetivo, recursos, procedimiento, resultados y evidencias en inglés.
2. Usar una plantilla IEEE aceptada por el profesor en Overleaf o el entorno LaTeX del grupo.
3. Mantener Introduction, Theoretical Framework, Development, Results y Conclusion.
4. En Development, separar acceso físico, monitoreo, Microsoft 365 y OneLogin.
5. Usar la tabla de pruebas en Results. Describir limitaciones y adaptaciones.
6. Citar las fuentes oficiales utilizadas; no copiar texto extenso.
7. Exportar los diagramas PDF a PNG para insertarlos como figuras. Mantener su título y descripción.
8. Compilar PDF, abrirlo y comprobar nombres, tablas, figuras y referencias.
9. Preparar presentación breve con empresa, red, controles, recorrido y resultados.
10. Preparar los entregables acordados sin incluir información personal en el repositorio.

Los diagramas PDF y LaTeX están fuera de las guías para poder insertarlos en informe y diapositivas. El organigrama que conserve vacantes no debe presentarse como lista final completa.

Entregan

Lista de cotejo con evidencias, resultados de pruebas, limitaciones, informe final en inglés, presentación y lista impresa. Registrar quién revisó cada bloque.

Referencias y videos

- Microsoft: alta de usuarios, con video oficial.
- Video oficial OneLogin: roles y mappings.
- Video oficial OneLogin: ciclo de vida.
- Frigate: grabación y exportación.
- Overleaf: primer proyecto LaTeX.
- Plantillas IEEE: confirmar con el profesor la variante exigida.
- Referencias y videos del paquete (REFERENCIAS_Y_VIDEOS.pdf).